

# Аудит IT-инфраструктуры предприятия партнера

ВКР партнера: «Платформа бенчмаркинга эффективности магазинов торговой сети на основе DEA-анализа»

## 1. Описание предприятия

### 1.1. Общая информация

Моделируемая компания - ООО «РитейлАналитика» - IT-компания, специализирующаяся на разработке и сопровождении аналитических решений для розничной торговли. Основным продуктом компании - DEA-платформа бенчмаркинга эффективности магазинов, предоставляемая торговым сетям по модели SaaS с возможностью on-premise развертывания.

| Параметр           | Значение                                                            |
|--------------------|---------------------------------------------------------------------|
| Название           | ООО «РитейлАналитика»                                               |
| Сфера деятельности | Разработка и внедрение аналитических IT-решений для retail-сегмента |
| Размер компании    | 45 сотрудников                                                      |
| Год основания      | 2021                                                                |
| Основной офис      | Москва, дополнительный центр разработки - Воронеж                   |
| Ключевые клиенты   | Региональные торговые сети (продуктовый retail, DIY, fashion)       |
| Модель монетизации | SaaS-подписка + услуги внедрения и сопровождения                    |

### 1.2. Основные бизнес-процессы, зависящие от IT

#### *Процесс 1. Разработка и поддержка DEA-платформы*

Ключевой производственный процесс компании. Включает проектирование архитектуры, разработку backend и frontend, моделирование DEA-алгоритмов, тестирование и развертывание. Полностью зависит от IT-инфраструктуры разработки: системы контроля версий, CI/CD-конвейера, тестовых сред, корпоративных репозиторий.

#### *Процесс 2. Эксплуатация и сопровождение клиентских инсталляций*

Включает развертывание платформы у клиентов, ETL-интеграцию с источниками данных (ERP, POS, BI-системы), мониторинг работы платформы у каждого клиента, обработку инцидентов, выпуск обновлений и патчей. Зависит от инфраструктуры мониторинга, ITSM-системы и облачных ресурсов.

#### *Процесс 3. Аналитическое консультирование и обучение клиентов*

Включает методологическую поддержку клиентов: настройку DEA-моделей под специфику конкретной сети, обучение пользователей, формирование пользовательской документации, проведение демонстраций для потенциальных клиентов. Зависит от платформ обучения, CRM-системы и инфраструктуры демонстрационных стендов.

#### *Процесс 4. Продажи и работа с клиентами*

Включает поиск и квалификацию лидов, демонстрации продукта, подготовку коммерческих предложений, заключение договоров, сбор обратной связи. Зависит от CRM-системы, инфраструктуры коммуникаций (видеосвязь, телефония, корпоративная почта).

## 2. Роль IT в бизнес-процессах компании

Для каждого ключевого бизнес-процесса используются минимум две IT-системы. Ниже приведены связки «процесс → системы → роль системы → метрики мониторинга».

### 2.1. Разработка и поддержка DEA-платформы

| Система                   | Версия / провайдер   | Назначение в процессе                                                                         |
|---------------------------|----------------------|-----------------------------------------------------------------------------------------------|
| GitLab Self-Hosted        | 16.x                 | Система контроля версий, code review, управление ветками, хранение всех артефактов разработки |
| Jenkins + Docker Registry | Jenkins 2.4 / Harbor | CI/CD-конвейер сборки, автоматизированного тестирования и публикации Docker-образов           |
| Jira Software             | Cloud                | Управление задачами, спринтами, backlog'ом разработки (Scrum-методология)                     |
| Confluence                | Cloud                | База знаний разработки: архитектурные решения, ADR, технические спецификации, runbook'и       |

#### *Метрики мониторинга IT-систем процесса*

| Система | Метрика                               | Норма         | Предупреждение | Критично  |
|---------|---------------------------------------|---------------|----------------|-----------|
| GitLab  | Доступность сервиса                   | $\geq 99.5\%$ | 99–99.5 %      | < 99%     |
| GitLab  | Время отклика API                     | $\leq 500$ мс | 500–1000 мс    | > 1000 мс |
| GitLab  | Использование дискового пространства  | $\leq 70\%$   | 70–85%         | > 85%     |
| Jenkins | Время сборки master-ветки             | $\leq 15$ мин | 15–25 мин      | > 25 мин  |
| Jenkins | Доля успешных сборок за неделю        | $\geq 90\%$   | 80–90%         | < 80%     |
| Jenkins | Очередь задач (build queue)           | $\leq 5$      | 5–10           | > 10      |
| Jira    | Доступность сервиса                   | $\geq 99.9\%$ | 99.5–99.9%     | < 99.5%   |
| Jira    | Время отклика веб-интерфейса          | $\leq 2$ сек  | 2–4 сек        | > 4 сек   |
| Jira    | Количество просроченных задач спринта | $\leq 2$      | 3–5            | > 5       |

Алерты направляются ответственным: GitLab/Jenkins - DevOps-инженеру в Telegram-канал #devops-alerts; Jira - менеджеру проекта по электронной почте. Критические алерты дублируются SMS-уведомлением.

### 2.2. Эксплуатация и сопровождение клиентских инсталляций

| Система                 | Версия / провайдер          | Назначение в процессе                                                        |
|-------------------------|-----------------------------|------------------------------------------------------------------------------|
| Prometheus + Grafana    | Prometheus 2.5 / Grafana 11 | Сбор метрик и визуализация состояния всех клиентских инсталляций платформы   |
| Elasticsearch + Kibana  | ELK Stack 8.x               | Централизованное хранение и анализ логов DEA-модулей и ETL-процессов         |
| Jira Service Management | Cloud                       | Регистрация и обработка инцидентов клиентов, SLA-контроль, эскалация         |
| Apache Airflow          | 2.8                         | Оркестрация ETL-процессов загрузки данных из систем клиентов в DEA-платформу |

### Метрики мониторинга IT-систем процесса

| Система       | Метрика                               | Норма          | Предупреждение | Критично |
|---------------|---------------------------------------|----------------|----------------|----------|
| Prometheus    | Доступность сервиса                   | $\geq 99.95\%$ | 99.5–99.95%    | < 99.5%  |
| Prometheus    | Задержка сбора метрик                 | $\leq 30$ сек  | 30–60 сек      | > 60 сек |
| Prometheus    | Использование оперативной памяти      | $\leq 75\%$    | 75–90%         | > 90%    |
| Elasticsearch | Состояние кластера                    | Green          | Yellow         | Red      |
| Elasticsearch | Задержка индексации логов             | $\leq 5$ сек   | 5–15 сек       | > 15 сек |
| Elasticsearch | Использование дисков                  | $\leq 70\%$    | 70–85%         | > 85%    |
| Jira SM       | Время реакции на критический инцидент | $\leq 30$ мин  | 30–60 мин      | > 60 мин |
| Jira SM       | Доля инцидентов в SLA                 | $\geq 95\%$    | 85–95%         | < 85%    |
| Jira SM       | Среднее время устранения (MTTR)       | $\leq 4$ ч     | 4–8 ч          | > 8 ч    |
| Airflow       | Доля успешных DAG-запусков            | $\geq 98\%$    | 90–98%         | < 90%    |
| Airflow       | Длительность выполнения ETL-задач     | $\leq 30$ мин  | 30–60 мин      | > 60 мин |
| Airflow       | Количество задач в статусе failed/day | $\leq 5$       | 5–15           | > 15     |

## 2.3. Аналитическое консультирование и обучение клиентов

| Система                  | Версия / провайдер     | Назначение в процессе                                                        |
|--------------------------|------------------------|------------------------------------------------------------------------------|
| Moodle LMS               | 4.3                    | Платформа онлайн-обучения клиентов: курсы, тесты, сертификация пользователей |
| Демо-стенд DEA-платформы | Внутренняя инсталляция | Изолированная среда с обезличенными данными для                              |

| Система                            | Версия / провайдер | Назначение в процессе                                                                   |
|------------------------------------|--------------------|-----------------------------------------------------------------------------------------|
|                                    |                    | проведения демонстраций и обучения                                                      |
| Microsoft 365 (Teams + SharePoint) | Enterprise         | Видеовстречи с клиентами, хранение пользовательской документации и обучающих материалов |

### *Метрики мониторинга IT-систем процесса*

| Система    | Метрика                              | Норма         | Предупреждение | Критично  |
|------------|--------------------------------------|---------------|----------------|-----------|
| Moodle LMS | Доступность                          | $\geq 99\%$   | 97–99%         | < 97%     |
| Moodle LMS | Время загрузки урока                 | $\leq 3$ сек  | 3–6 сек        | > 6 сек   |
| Moodle LMS | Количество одновременных сессий      | $\leq 100$    | 100–150        | > 150     |
| Демо-стенд | Доступность                          | $\geq 99.5\%$ | 98–99.5%       | < 98%     |
| Демо-стенд | Время отклика DEA-расчета (демо)     | $\leq 2$ мин  | 2–4 мин        | > 4 мин   |
| Демо-стенд | Свежесть тестовых данных             | $\leq 7$ дней | 7–14 дней      | > 14 дней |
| Teams      | Качество видеосвязи (потери пакетов) | $\leq 1\%$    | 1–3%           | > 3%      |
| Teams      | Доступность сервиса                  | $\geq 99.9\%$ | 99–99.9%       | < 99%     |
| Teams      | Время до подключения к встрече       | $\leq 5$ сек  | 5–10 сек       | > 10 сек  |

## 2.4. Продажи и работа с клиентами

| Система                   | Версия / провайдер  | Назначение в процессе                                                           |
|---------------------------|---------------------|---------------------------------------------------------------------------------|
| Bitrix24 CRM              | Облачная подписка   | Воронка продаж, учет лидов, контактов, сделок, история коммуникаций с клиентами |
| Яндекс 360 для бизнеса    | Корпоративный тариф | Корпоративная электронная почта домена ritailanalytics.ru, календари, диск      |
| IP-телефония MANGO OFFICE | Облачная            | Запись звонков, интеграция с CRM, аналитика звонков отдела продаж               |

### *Метрики мониторинга IT-систем процесса*

| Система  | Метрика                                | Норма          | Предупреждение | Критично |
|----------|----------------------------------------|----------------|----------------|----------|
| Bitrix24 | Доступность сервиса                    | $\geq 99.5\%$  | 98–99.5%       | < 98%    |
| Bitrix24 | Время отклика на действия пользователя | $\leq 1.5$ сек | 1.5–3 сек      | > 3 сек  |

| Система    | Метрика                             | Норма     | Предупреждение | Критично  |
|------------|-------------------------------------|-----------|----------------|-----------|
| Bitrix24   | Доля сделок без активности > 7 дней | ≤ 10%     | 10–20%         | > 20%     |
| Яндекс 360 | Доступность почты                   | ≥ 99.9%   | 99–99.9%       | < 99%     |
| Яндекс 360 | Задержка доставки писем             | ≤ 30 сек  | 30–120 сек     | > 120 сек |
| Яндекс 360 | Использование квоты дисков          | ≤ 70%     | 70–90%         | > 90%     |
| MANGO      | Доступность телефонии               | ≥ 99.5%   | 98–99.5%       | < 98%     |
| MANGO      | Доля пропущенных звонков            | ≤ 5%      | 5–10%          | > 10%     |
| MANGO      | Качество записи звонков (битрейт)   | ≥ 64 kbps | 32–64 kbps     | < 32 kbps |

## 3. Инвентаризация IT-инфраструктуры

### 3.1. Аппаратное обеспечение

Инфраструктура компании построена по гибридной модели: основная продуктовая нагрузка размещена в облаке Yandex Cloud, корпоративные сервисы и сервисы разработки - частично on-premise (серверная стойка в офисе), частично облачные SaaS-сервисы. Рабочие станции сотрудников - корпоративные ноутбуки.

| № | Тип                    | Назначение                                          | Конфигурация / модель                                           | ОС                      |
|---|------------------------|-----------------------------------------------------|-----------------------------------------------------------------|-------------------------|
| 1 | Облачный сервер (VPS)  | Production: основной кластер DEA-платформы (master) | 16 vCPU / 64 GB RAM / 500 GB SSD, Yandex Cloud                  | Ubuntu Server 22.04 LTS |
| 2 | Облачный сервер (VPS)  | Production: реплика DEA-платформы (failover)        | 16 vCPU / 64 GB RAM / 500 GB SSD, Yandex Cloud                  | Ubuntu Server 22.04 LTS |
| 3 | Облачный сервер (VPS)  | База данных PostgreSQL (primary)                    | 8 vCPU / 32 GB RAM / 1 TB SSD, Yandex Cloud                     | Ubuntu Server 22.04 LTS |
| 4 | Облачный сервер (VPS)  | База данных PostgreSQL (replica)                    | 8 vCPU / 32 GB RAM / 1 TB SSD, Yandex Cloud                     | Ubuntu Server 22.04 LTS |
| 5 | Облачный сервер (VPS)  | Staging / тестовая среда                            | 8 vCPU / 16 GB RAM / 200 GB SSD, Yandex Cloud                   | Ubuntu Server 22.04 LTS |
| 6 | Сервер on-premise (1U) | GitLab Self-Hosted + Jenkins                        | Dell PowerEdge R650, 2× Xeon Silver / 64 GB / 2 TB SSD RAID-10  | Ubuntu Server 22.04 LTS |
| 7 | Сервер on-premise (1U) | Сервер мониторинга (Prometheus + Grafana + ELK)     | Dell PowerEdge R650, 2× Xeon Silver / 128 GB / 4 TB SSD RAID-10 | Ubuntu Server 22.04 LTS |
| 8 | Сервер on-premise (1U) | Файловый сервер + резервные копии                   | Dell PowerEdge R750, 2× Xeon Silver / 32 GB / 24 TB HDD RAID-6  | TrueNAS SCALE 23        |

| №  | Тип                                             | Назначение                                       | Конфигурация / модель                                | ОС                            |
|----|-------------------------------------------------|--------------------------------------------------|------------------------------------------------------|-------------------------------|
| 9  | NAS-хранилище                                   | Резервные копии второго уровня (offsite-replica) | Synology RS1221+, 8× 8 TB HDD, общий объем 48 TB raw | DSM 7.2                       |
| 10 | Сетевое оборудование                            | Маршрутизатор / межсетевой экран офиса           | MikroTik CCR2004-1G-12S+2XS                          | RouterOS 7.x                  |
| 11 | Сетевое оборудование                            | Коммутатор офисной сети                          | MikroTik CRS328-24P-4S+                              | SwOS / RouterOS               |
| 12 | Точки доступа Wi-Fi                             | Беспроводная корпоративная сеть (3 шт.)          | Ubiquiti UniFi U6-Pro                                | UniFi Network 8.x             |
| 13 | Рабочие станции разработчиков (20 шт.)          | Разработка и тестирование                        | Lenovo ThinkPad T14 / T16, i7 / 32 GB RAM / 1 TB SSD | Windows 11 Pro / Ubuntu 22.04 |
| 14 | Рабочие станции аналитиков (10 шт.)             | Аналитика, моделирование, документация           | Lenovo ThinkPad E16, i5 / 16 GB RAM / 512 GB SSD     | Windows 11 Pro                |
| 15 | Рабочие станции отдела продаж и админ. (15 шт.) | Продажи, CRM, документооборот                    | HP ProBook 450, i5 / 16 GB RAM / 512 GB SSD          | Windows 11 Pro                |
| 16 | МФУ сетевые (2 шт.)                             | Печать и сканирование документов                 | Kyocera ECOSYS M3145dn                               | -                             |

### **Оценка состояния аппаратного обеспечения**

В целом текущий парк техники достаточен для решения текущих задач компании. Серверная инфраструктура развернута в гибридной модели, что обеспечивает баланс между гибкостью облака и контролем над критичными корпоративными сервисами. Рабочие станции сотрудников обновлены в 2023–2024 годах и закрывают потребности производственного процесса.

Основные ограничения текущего парка: файловый сервер на дисках HDD (медленная скорость восстановления резервных копий - критичная точка при росте числа клиентов); отсутствие резервного межсетевого экрана (single point of failure в сетевой инфраструктуре офиса); 30% рабочих станций отдела продаж в эксплуатации более 4 лет - приближается срок плановой замены.

## **3.2. Программное обеспечение**

### **Операционные системы**

- Ubuntu Server 22.04 LTS - на всех серверных мощностях (production, staging, on-premise серверы)
- TrueNAS SCALE 23.10 - для файлового сервера с резервными копиями
- Windows 11 Pro - на корпоративных ноутбуках (~75% рабочих станций)
- Ubuntu 22.04 LTS - на ноутбуках части разработчиков (~25% рабочих станций)

### **Базы данных**

- PostgreSQL 16 - основная СУБД для DEA-платформы и клиентских данных
- ClickHouse 24.x - аналитическая СУБД для агрегатов и отчетности
- Redis 7.x - кэширование и очереди задач

- Elasticsearch 8.x - хранилище логов и поисковых индексов

### ***Прикладное программное обеспечение***

- Среды разработки: JetBrains IntelliJ IDEA Ultimate, PyCharm Professional, VS Code, DataGrip
- Системы коллективной работы: Microsoft 365 (Teams, SharePoint, OneDrive), Confluence, Jira Software, Jira Service Management
- CRM и продажи: Bitrix24 (облачная подписка), интеграция с IP-телефонией MANGO OFFICE
- CI/CD и DevOps: GitLab CE Self-Hosted, Jenkins, Docker, Kubernetes (managed Yandex Cloud), Harbor Registry
- Мониторинг: Prometheus, Grafana, Alertmanager, ELK Stack (Elasticsearch + Logstash + Kibana)
- ETL и data engineering: Apache Airflow 2.8, Great Expectations, dbt
- Аналитика и моделирование: Python 3.11 (pandas, numpy, scipy, scikit-learn, pyDEA), Jupyter Lab, R Studio
- Безопасность: Kaspersky Endpoint Security, Bitwarden Enterprise (менеджер паролей)

### ***Управление лицензиями***

Управление лицензиями централизовано: ответственным является системный администратор. Реестр лицензий ведется в Confluence в виде структурированной страницы с привязкой к ответственному, дате окончания и стоимости продления.

- Open-source ПО (Ubuntu, PostgreSQL, Redis, Elasticsearch до Basic-уровня, Python, Apache Airflow, Prometheus, Grafana OSS) - используется без коммерческого лицензирования
- Коммерческие SaaS-подписки (Jira, Confluence, Microsoft 365, Bitrix24, JetBrains All Products Pack, MANGO OFFICE) - оплачиваются ежегодно, автоматическое продление с уведомлением за 30 дней
- Коммерческие per-seat лицензии (Windows 11 Pro, Kaspersky Endpoint Security) - закупаются партиями при найме новых сотрудников
- Реестр лицензий в Confluence содержит: название, тип (SaaS / per-seat / per-server), количество, дата начала и окончания, стоимость, ответственный, ссылка на договор в SharePoint

## **3.3. Сетевая инфраструктура**

Сеть компании построена по сегментированной модели с физическим разделением критичных контуров. Центральная точка - маршрутизатор MikroTik CCR2004 с настроенным межсетевым экраном и VPN-сервером.

### ***Сегментация локальной сети***

- VLAN 10 «Production servers» (10.10.10.0/24) - on-premise серверы, доступ только с рабочих станций администраторов и через VPN
- VLAN 20 «Workstations» (10.10.20.0/24) - корпоративные ноутбуки сотрудников, доступ в интернет через прокси, доступ к серверам - по белым спискам
- VLAN 30 «Guests» (10.10.30.0/24) - гостевая Wi-Fi-сеть, полностью изолирована от внутренних ресурсов
- VLAN 40 «Voice» (10.10.40.0/24) - IP-телефония MANGO OFFICE и VoIP-устройства
- VLAN 50 «IoT/Print» (10.10.50.0/24) - сетевые принтеры, IoT-устройства

### ***Доступ в интернет***

- Основной канал: Ростелеком, 500 Мбит/с симметричный, с резервированием по SLA провайдера
- Резервный канал: МТС бизнес-интернет, 200 Мбит/с, автоматическое переключение через MikroTik
- Корпоративный VPN: WireGuard для удаленных сотрудников и доступа к on-premise серверам

#### **Облачная сетевая инфраструктура**

- Изолированная VPC в Yandex Cloud, разделенная на подсети: public (для load balancer), private app (для приложений), private db (для баз данных)
- Доступ к облачным серверам только через bastion-host с MFA
- Site-to-site VPN между офисной сетью и облачной VPC

## **4. Безопасность IT-инфраструктуры**

### **4.1. Анализ рисков безопасности**

Ниже приведены 5 наиболее вероятных угроз безопасности IT-инфраструктуры с оценкой потенциального ущерба. Угрозы ранжированы по уровню риска (вероятность × влияние).

| Угроза                                                                                                         | Вероятность | Влияние     | Потенциальный ущерб                                                                                                                            |
|----------------------------------------------------------------------------------------------------------------|-------------|-------------|------------------------------------------------------------------------------------------------------------------------------------------------|
| Утечка данных клиентов через компрометацию учетной записи разработчика (фишинг, кража токенов)                 | Средняя     | Критическое | Финансовые потери до 5–8 млн ₽ (компенсации клиентам, штрафы по 152-ФЗ), репутационный ущерб, риск потери крупных клиентов                     |
| Ransomware-атака на on-premise инфраструктуру (шифрование GitLab, файлового сервера, серверов мониторинга)     | Средняя     | Высокое     | Остановка разработки на 5–14 дней, потеря коммитов, простой клиентских инсталляций при невозможности оперативного исправления, ущерб 3–6 млн ₽ |
| DDoS-атака на production-окружение DEA-платформы у крупного клиента                                            | Высокая     | Среднее     | Простой клиентских инсталляций до 4–8 часов, нарушение SLA с клиентом, штрафы по контракту 200–500 тыс ₽, отток клиентов                       |
| Эксплуатация уязвимости в зависимостях open-source ПО (например, известная CVE в Elasticsearch или PostgreSQL) | Высокая     | Высокое     | Удаленное выполнение кода, утечка данных, ущерб 2–5 млн ₽, обязательное уведомление клиентов и регуляторов                                     |
| Инсайдерская угроза: умышленный слив исходного кода DEA-моделей увольняющимся сотрудником                      | Низкая      | Высокое     | Потеря конкурентного преимущества, появление аналогичной платформы у конкурента, ущерб 8–15 млн ₽ упущенной выручки за 2–3 года                |

### **4.2. Существующие меры безопасности**



| Мера                                | Описание                                                                                                                                                        | Оценка эффективности                                                                                                                      |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| Антивирусная защита                 | Kaspersky Endpoint Security на всех рабочих станциях и серверах с автоматическим обновлением баз сигнатур                                                       | Достаточная - блокирует известные угрозы; недостаточна против целевых атак и zero-day                                                     |
| Межсетевой экран                    | MikroTik с правилами фильтрации трафика, NAT, port knocking для административного доступа                                                                       | Достаточная для периметра офиса; для облачной инфраструктуры используются Security Groups Yandex Cloud                                    |
| Многофакторная аутентификация (MFA) | Внедрена для критичных сервисов: GitLab, Jira, корпоративная почта, VPN, bastion-host, Bitwarden                                                                | Эффективная - снижает риск компрометации учетных записей на ~90%                                                                          |
| Политика паролей                    | Минимум 14 символов, обязательная смена раз в 90 дней для административных учетных записей, обязательное использование Bitwarden                                | Достаточная для большинства угроз, но плановая ротация - устаревший подход (NIST с 2020 г. рекомендует от нее отказаться при наличии MFA) |
| Резервное копирование               | Ежедневные инкрементальные и еженедельные полные копии: производственные БД → S3 Yandex Cloud + offsite-репликация на Synology в офисе. Хранение 30 дней        | Достаточная по частоте; недостаточно проверена тестовым восстановлением - DR-учения не проводились                                        |
| Шифрование данных                   | Шифрование дисков серверов (LUKS), HTTPS для всех веб-интерфейсов, шифрование клиентских данных at rest (PostgreSQL TDE)                                        | Эффективная для защиты данных at rest и in transit                                                                                        |
| Управление обновлениями             | Автоматические обновления безопасности на серверах (unattended-upgrades), ежемесячный аудит уязвимостей зависимостей через Trivy и Dependabot                   | Достаточная для типовых уязвимостей; для критичных CVE - отсутствует процесс экстренного патчинга                                         |
| Журналирование и аудит              | Централизованный сбор логов в ELK Stack, ретенция 90 дней, алерты на подозрительную активность (множественные неудачные входы, доступ из необычных гео-локаций) | Эффективная по сбору; отсутствует SIEM-уровень корреляции событий и реакции                                                               |
| Обучение сотрудников                | Ежегодный курс по информационной безопасности (фишинг, социальная инженерия) на платформе Moodle с итоговым тестом                                              | Базовая, но недостаточная - нет регулярных фишинг-тренировок (имитация атак)                                                              |

### **Общая оценка достаточности мер защиты**

Существующие меры закрывают базовый уровень угроз и соответствуют требованиям 152-ФЗ для оператора персональных данных. Однако для защиты от выявленных в разделе 4.1 угроз есть несколько критических пробелов:

- Отсутствует регулярное тестирование процедур восстановления (DR drills) - резервные копии есть, но нет уверенности, что они корректно восстановятся
- Нет защиты от DDoS уровня application layer - текущая защита Yandex Cloud работает на network layer и пропускает целевые атаки
- Не внедрены процедуры экстренного патчинга критичных CVE - окно эксплуатации может составлять недели
- Отсутствуют регулярные имитации фишинговых атак - реальная подготовленность сотрудников не измеряется
- Нет процедур контроля доступа уволенных сотрудников к корпоративным репозиториям (offboarding-checklist неполный)

## **5. Рекомендации по управлению проектом модернизации**

Проект модернизации направлен на масштабирование платформы для подключения нового крупного клиента - торговой сети из 120 магазинов (заказчик ВКР партнера).

### **5.1. Цели и задачи проекта**

#### **Стратегические цели**

- Масштабировать DEA-платформу для обработки данных торговой сети из 120 магазинов без потери качества SLA
- Интегрировать платформу с инфраструктурой клиента: ERP, POS-системой и BI-инструментами
- Обеспечить выполнение SLA по доступности  $\geq 99.5\%$  и времени DEA-расчета  $\leq 10$  минут на полную сеть
- Достичь окупаемости проекта на стороне клиента за 9–12 месяцев

#### **Тактические задачи**

- Расширить production-кластер с учетом 4-кратного роста объема обрабатываемых данных
- Настроить ETL-процессы загрузки данных из ERP и POS клиента (ожидается до 50 ГБ данных в месяц)
- Адаптировать DEA-модели под специфику продуктового retail (товарные категории, сезонность)
- Внедрить мониторинг качества данных (Great Expectations) с автоматическими алертами
- Обучить 40 сотрудников клиента (региональные менеджеры, аналитики)

### **5.2. План проекта**

| Этап                                 | Содержание                                                                                                                            | Сроки   | Длительность |
|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|---------|--------------|
| 1. Pre-sales и техническая дискавери | Анализ инфраструктуры клиента (ERP, POS, BI), технический аудит источников данных, согласование архитектуры интеграции, подготовка ТЗ | Месяц 1 | 4 недели     |

| Этап                                        | Содержание                                                                                                                                                      | Сроки                       | Длительность |
|---------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------|--------------|
| 2. Архитектура и подготовка инфраструктуры  | Расширение production-кластера в Yandex Cloud, развертывание изолированного контура для клиента, настройка VPN и каналов передачи данных                        | Месяц 2 – середина месяца 3 | 6 недель     |
| 3. Разработка и интеграция                  | Разработка коннекторов к ERP и POS клиента, настройка ETL-процессов в Airflow, калибровка DEA-моделей на данных клиента, разработка кастомных отчетов и heatmap | Середина месяца 3 – месяц 5 | 10 недель    |
| 4. Тестирование и пилот                     | Функциональное и нагрузочное тестирование, пилот на 20 магазинах клиента, верификация качества DEA-score экспертной комиссией клиента, доработки                | Месяц 6                     | 4 недели     |
| 5. Промышленное внедрение и масштабирование | Поэтапное подключение всех 120 магазинов сети, перенос в production, мониторинг SLA, оперативная техподдержка hypercare                                         | Месяц 7 – месяц 8           | 8 недель     |
| 6. Обучение и передача в эксплуатацию       | Обучение сотрудников клиента (онлайн-курсы на Moodle, очные сессии), подготовка пользовательской документации, передача на регулярное сопровождение             | Месяц 8 – месяц 9           | 4 недели     |
| Общая длительность                          | -                                                                                                                                                               | 9 месяцев                   | 36 недель    |

### 5.3. Управление рисками проекта

| Риск                                                                                       | Вероятность | Влияние | Меры смягчения                                                                                                                                                     |
|--------------------------------------------------------------------------------------------|-------------|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Низкое качество данных в системах клиента (пропуски, ошибки в выручке/ФОТ/трафике)         | Высокая     | Высокое | Внедрение data quality checks на этапе ETL, обязательная валидация через Great Expectations, согласование с клиентом SLA по качеству источников $\geq 97\%$        |
| Задержка предоставления доступа к ERP/POS со стороны IT-отдела клиента                     | Высокая     | Среднее | Фиксация сроков в договоре, эскалация на уровне руководства, параллельная подготовка на тестовых данных, недельные статус-встречи                                  |
| Соппротивление пользователей платформе (региональные менеджеры не используют рекомендации) | Средняя     | Высокое | Раннее вовлечение ключевых пользователей в проектирование, пилот на лояльных магазинах, постпроектное обучение, KPI использования платформы для менеджеров клиента |
| Превышение бюджета проекта из-за переоценки                                                | Средняя     | Среднее | Дискавери-этап перед фиксацией стоимости,                                                                                                                          |

| Риск                                                                                  | Вероятность | Влияние | Меры смягчения                                                                                                                                            |
|---------------------------------------------------------------------------------------|-------------|---------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| сложности интеграции с устаревшими системами клиента                                  |             |         | резерв 15% бюджета, fixed-price только после этапа архитектуры                                                                                            |
| Уход ключевого разработчика с проекта (DEA-инженер, знающий специфику)                | Низкая      | Высокое | Bus factor $\geq 2$ для каждой компетенции, обязательная документация решений в Confluence, парное программирование на критичных компонентах              |
| Изменение требований законодательства (152-ФЗ, новые требования к локализации данных) | Низкая      | Среднее | Мониторинг изменений регуляторики через юридический отдел, использование российских облачных провайдеров (Yandex Cloud), хранение данных на территории РФ |

## 5.4. Заинтересованные стороны и коммуникации

| Stakeholder                                 | Сторона         | Интерес в проекте                                                                           | Канал и частота коммуникации                                                      |
|---------------------------------------------|-----------------|---------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| Спонсор проекта (CEO клиента)               | Клиент          | ROI, бизнес-эффект, репутация перед советом директоров                                      | Ежемесячные статусы (face-to-face или Teams) + executive-отчеты                   |
| Руководитель проекта со стороны клиента     | Клиент          | Соблюдение сроков, бюджета, качества                                                        | Еженедельные синхронизации по Teams + Jira-доступ для контроля задач              |
| IT-директор клиента                         | Клиент          | Безопасность интеграции, соответствие 152-ФЗ, минимальное влияние на текущую инфраструктуру | Двухнедельные технические встречи, общий Slack/Telegram-канал                     |
| Региональные менеджеры клиента (40 чел.)    | Клиент          | Удобство платформы, реальная польза для управления                                          | Презентации на этапах MVP и пилота, ежеквартальные user-surveys, обучающие сессии |
| Руководитель проекта со стороны исполнителя | РитейлАналитика | Соблюдение плана, маржинальность                                                            | Внутренние ежедневные стендапы + еженедельные синхронизации с клиентом            |
| Команда разработки и интеграции             | РитейлАналитика | Качество техрешения, отсутствие технического долга                                          | Ежедневные стендапы, ретроспективы по итогам каждого этапа                        |
| CEO/учредители РитейлАналитики              | РитейлАналитика | Маржинальность, репутация, кейс для дальнейших продаж                                       | Ежемесячные executive-обзоры, оперативная эскалация critical issues               |
| Юридический отдел / DPO клиента             | Клиент          | Соответствие 152-ФЗ, отсутствие правовых рисков                                             | Согласования на этапах: договор, обработка ПДн, аудит безопасности                |

| Stakeholder                                   | Сторона        | Интерес в проекте                   | Канал и частота коммуникации                              |
|-----------------------------------------------|----------------|-------------------------------------|-----------------------------------------------------------|
| Подрядчики ETL/интеграций (если привлекаются) | Третьи стороны | Своевременная оплата, корректное ТЗ | Контрактные коммуникации, статус-встречи раз в две недели |

### ***Принципы коммуникаций***

- Единая точка контакта (SPOC) с обеих сторон - руководители проектов исполнителя и клиента, все официальные коммуникации проходят через них
- Прозрачность статуса проекта: все основные задачи и риски в Jira с доступом для клиента, еженедельный status-report по электронной почте
- Эскалационный путь: уровень 1 - РП ↔ РП (срок реакции 1 рабочий день); уровень 2 - IT-директор клиента ↔ CEO исполнителя (срок реакции 4 часа); уровень 3 - спонсоры с обеих сторон (немедленно)
- Документирование решений: все ключевые решения фиксируются в Confluence в виде ADR (Architecture Decision Records) с подписями обеих сторон
- Ретроспективы по итогам каждого этапа: выявление проблем, накопление best practices, корректировка плана следующего этапа